

Informationssicherheit & Datenschutz

Teil 2 von 2: Datenschutz

Prof. Dr. Thomas Städter

Nutzungsrechte

**© FOM Hochschule für Oekonomie & Management
gemeinnützige Gesellschaft mbH (FOM), Leimkugelstraße 6, 45141 Essen**

Dieses Werk ist urheberrechtlich geschützt und nur für den persönlichen Gebrauch im Rahmen der Veranstaltungen der FOM bestimmt.

Die durch die Urheberschaft begründeten Rechte (u. a. Vervielfältigung, Verbreitung, Übersetzung, Nachdruck) bleiben dem Urheber vorbehalten.

Das Werk oder Teile daraus dürfen nicht ohne schriftliche Genehmigung des Urhebers / der FOM reproduziert oder unter Verwendung elektronischer Systeme verarbeitet, vervielfältigt oder verbreitet werden. Dies schließt auch den Upload in soziale Medien oder andere digitale Plattformen ein.

Modul- / Veranstaltungsgliederung

1	Einführung
2	Ausgangslage und Herausforderungen
3	Technische und organisatorische Grundlagen
4	Cyber Security
5	Managementaufgaben
6	ISMS/ DSMS
7	Datenschutz
7.1	Allgemeine Begriffsbestimmungen
7.2	Grundsätze für die Verarbeitung personenbezogener Daten
7.3	Technische und organisatorische Maßnahmen
7.4	Pflichten der verantwortlichen Stelle
7.5	Betroffenenrechte
7.6	Aufbau- und Ablauforganisation
7.7	Internationaler Datenverkehr
7.8	Fallbeispiele

7.1

Allgemeine Begriffsbestimmungen

Was ist eigentlich Datenschutz?

Datenschutz ist der Schutz des Einzelnen vor den Gefahren, die eine Erhebung, Verarbeitung oder Nutzung seiner persönlichen Daten mit sich bringen kann.

Datenschutz ermöglicht die Sicherung des Grundrechtes auf informationelle Selbstbestimmung.

Hinweis:

Im Datenschutz werden nicht nur elektronische Daten betrachtet, sondern alle Arten von persönlichen Informationen. Das Medium (Papier, CD, USB-Stick oder Internetseite) spielt dabei keine Rolle.

Wofür steht “Informationelle Selbstbestimmung”?

Informationelle Selbstbestimmung ist das Recht des Einzelnen, grundsätzlich selbst über die Preisgabe und die Verwendung seiner personenbezogenen Daten zu bestimmen.

- Jede(r) entscheidet selbst, welche persönlichen Daten in welcher Form verwendet werden dürfen.
- Einschränkungen von diesem Grundrecht bedürfen einer gesetzlichen Grundlage.

Compliance, Bewusstsein schaffen

Für wen gilt die DSGVO?

- Jeder, der sich an der Datenverarbeitung von Unternehmen in der EU beteiligt
- Jeder, der Daten von Kunden, die sich in der EU befinden, verarbeitet
- Jeder, der die Aktivitäten von EU-Besuchern auf seiner eigenen Website oder in seiner eigenen App analysiert
- Verpflichtung ausländischer Unternehmen, eine Person innerhalb der EU zu benennen, die sie "hinsichtlich ihrer jeweiligen Verpflichtungen" "vertritt" (vgl. EG 80)

Bußgelder

- Jede (nationale) Behörde kann Bußgelder verhängen
- Missbrauch PbD von Kindern: 10 Mio. EUR oder 2% des weltweiten Umsatzes
- Missachtung inhaltlicher Regelungen: 20 Mio. oder 4% des weltweiten Umsatzes

Wann spielt Datenschutz eine Rolle?

Vertragsverhandlungen

- Risikobegrenzung durch Auftragsverarbeitung
- Definition der Datenherkunft und der Datenweitergabe
- Klare Bestimmung des Erhebungs- und Verarbeitungszweckes

Einstellung von Mitarbeitern

- Begrenzung der Datenerhebung und –verarbeitung auf die Zwecke des Beschäftigungsverhältnisses
- Verpflichtung der Mitarbeiter auf den Datenschutz
- Clear Desk-Policy und sicherer Umgang mit Daten

Betrieb einer Hotline, eines CRM oder eines DMS

- Einholung einer klaren Einwilligung
- Zweckbindung bei der Datenerhebung
- transparente Abläufe
- Dokumentation
- Hosting oder Cloud-Services

Andere ...

Begriffsbestimmungen

Personenbezogene Daten

Alle Daten, die sich auf eine identifizierbare Person beziehen: Kontaktdaten, Kommunikationsbericht, Geschlecht, Sprache, Standortverfolgung, Nationalität, IP-Adressen (in einigen Fällen)

Datenverarbeitung

Jede Aktivität, die mit persönlichen Daten durchgeführt wird. Sehr breiter Anwendungsbereich (offene Liste): Erhebung, Aufzeichnung, Organisation, Strukturierung, Speicherung, Anpassung oder Änderung, Wiederauffindung, Abfrage, Verwendung, Offenlegung durch Übermittlung, Verbreitung oder anderweitige Verfügbarmachung, Abgleich oder Kombination, Einschränkung, Löschung oder Zerstörung.

Datensubjekt / Betroffener

Die identifizierte oder identifizierbare natürliche Person, auf die sich die zu verarbeitenden Daten beziehen.

Verantwortlicher / Auftraggeber / Controller

Die Person/Einrichtung, die bestimmt, für welche Zwecke und mit welchen Mitteln personenbezogene Daten verarbeitet werden. Wenn ein Unternehmen entscheidet, "warum" und "wie" die personenbezogenen Daten verarbeitet werden sollen, dann ist das Unternehmen der für die Verarbeitung Verantwortliche.

Verarbeiter / Auftragnehmer / Processor

Die Person/Einrichtung, die personenbezogene Daten im Auftrag des für die Verarbeitung Verantwortlichen verarbeitet.

Personenbezogene Daten (pbD)

„... alle Informationen, die sich auf eine identifizierte oder identifizierbare natürliche Person (im Folgenden „betroffene Person“) beziehen; als identifizierbar wird eine natürliche Person angesehen, die direkt oder indirekt, insbesondere mittels Zuordnung zu einer Kennung wie einem Namen, zu einer Kennnummer, zu Standortdaten, zu einer Online-Kennung oder zu einem oder mehreren besonderen Merkmalen, die Ausdruck der physischen, physiologischen, genetischen, psychischen, wirtschaftlichen, kulturellen oder sozialen Identität dieser natürlichen Person sind, identifiziert werden kann;

[Art. 4, Abs. 1 DSGVO]

7.2

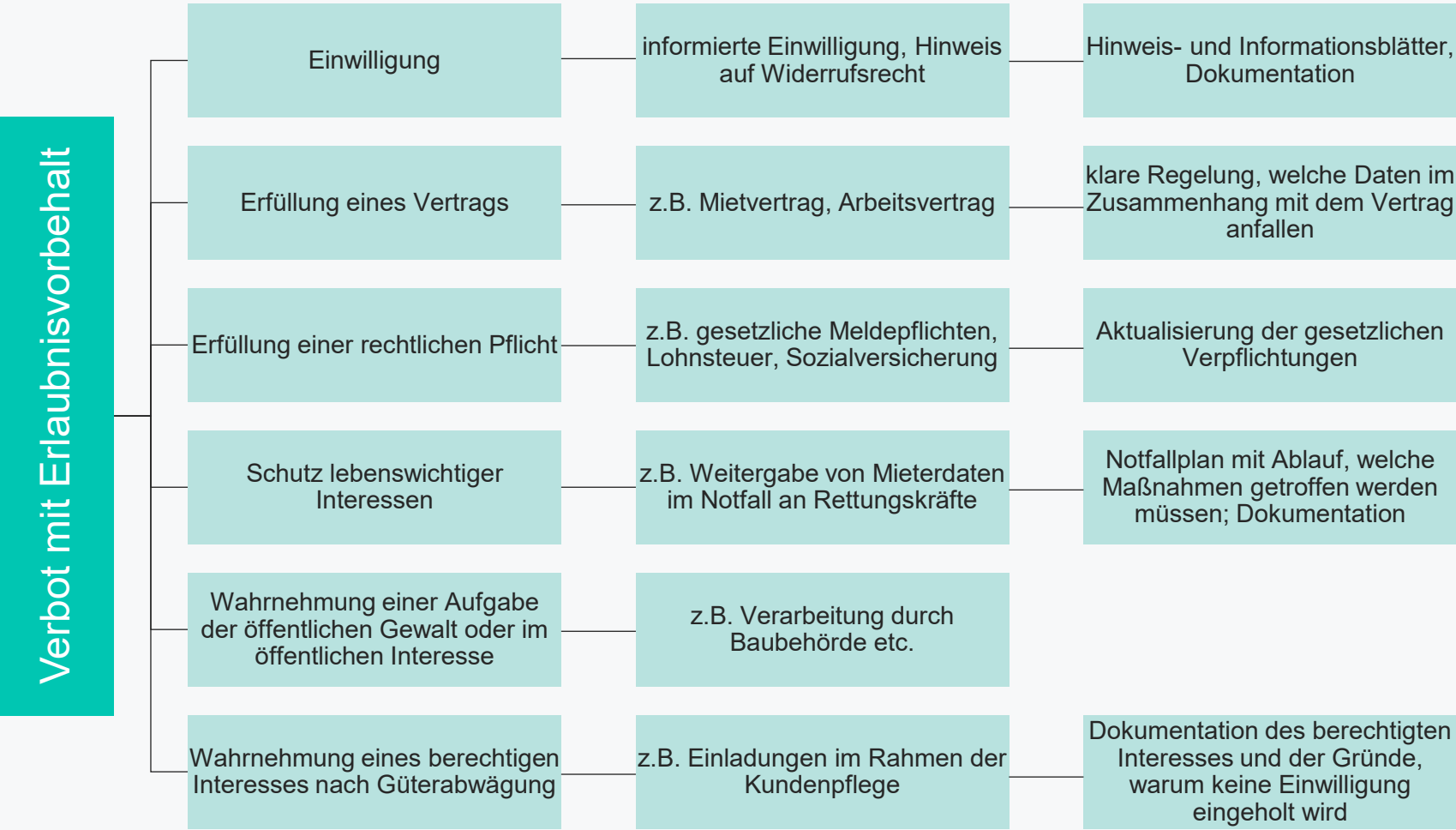
Grundsätze für die Verarbeitung personenbezogener Daten

Grundsätze für die Verarbeitung personenbezogener Daten



Quelle: vgl. Helfrich, 2018; Eigene Darstellung

Wann dürfen Daten gem. Art. 6 DSGVO verarbeitet werden?

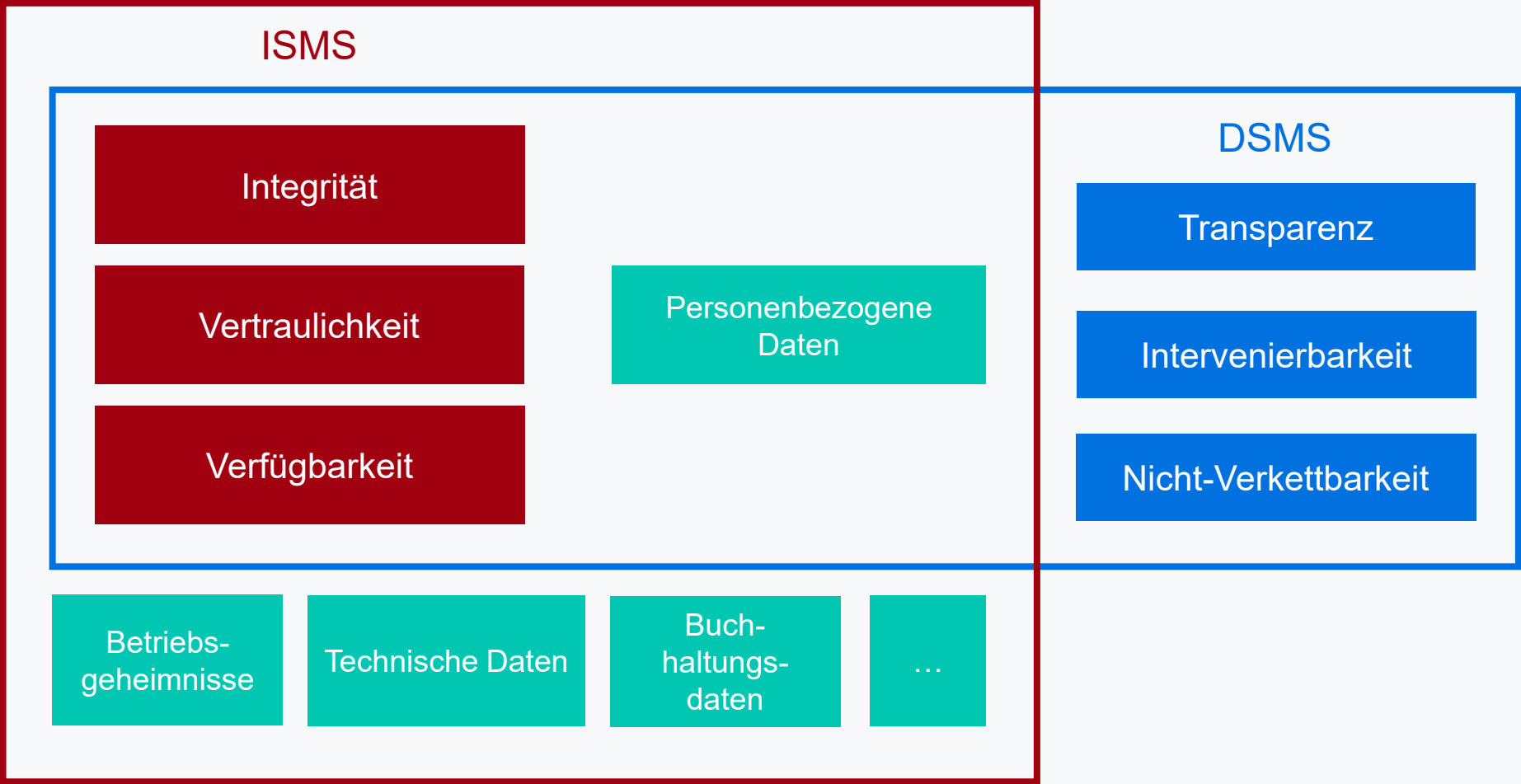


Quelle: Eigene Darstellung

Einwilligung

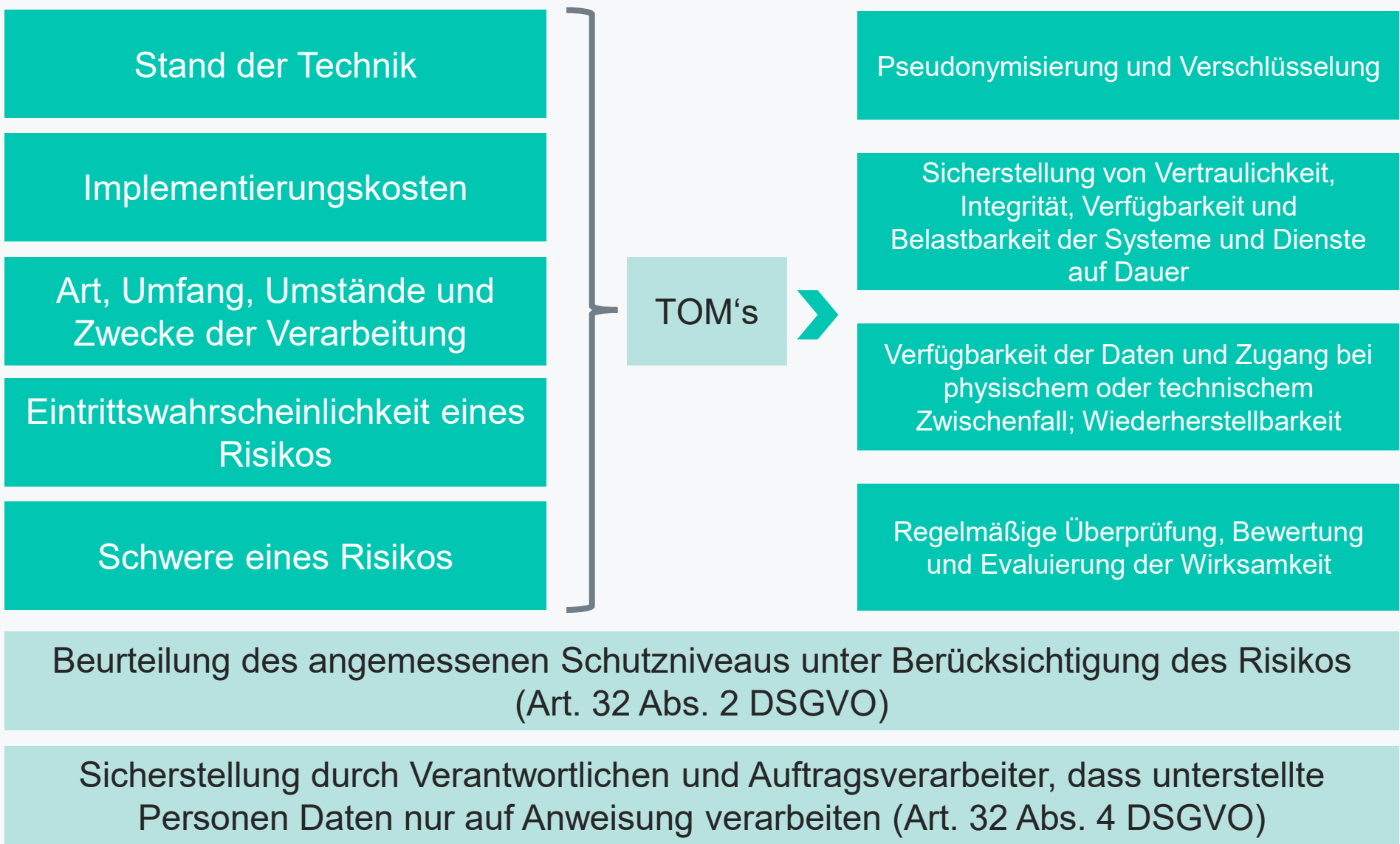
„...‘Einwilligung‘ der betroffenen Person (ist) jede **freiwillig** für den **bestimmten** Fall, in **informierter Weise** und **unmissverständlich** abgegebene Willensbekundung in Form einer Erklärung oder einer sonstigen **eindeutigen bestätigenden Handlung**, mit der die betroffene Person zu verstehen gibt, dass sie mit der **Verarbeitung** der sie betreffenden personenbezogenen Daten **einverstanden ist**; ...“ (Art. 4 Nr. 11 DSGVO)

- Beweislast für die wirksame Einwilligung liegt beim Verantwortlichen (Art. 7 Abs. 1 DSGVO)
- Einwilligung ist jederzeit widerruflich; Hinweis hierauf erforderlich.



Quelle: Schrahe & Städter, 2019

Technische und organisatorische Maßnahmen



Quelle: Eigene Darstellung

IT-Richtlinie als TOM

Präambel

Diese IT-Richtlinie soll die vom Unternehmen getroffenen Maßnahmen zum Schutz von (personenbezogenen) Daten vor unbefugter Kenntnisnahme durch Dritte oder nichtberechtigte Mitarbeiter unterstützen und darüber hinaus eine grundlegende Information für alle Mitarbeiter im Hinblick auf den Umgang mit Daten sein.

Das Dokument beschreibt Grundsätze zum Schutz von Mitarbeitern, Informationen, Systemen und Werten des Unternehmens und:

- betont die Verantwortlichkeit aller Mitarbeiterinnen und Mitarbeiter für die IT-Sicherheit und das Zusammenspiel von Systemen und Menschen.
- betont die Verantwortung der Führungskräfte für die Umsetzung innerhalb ihres Zuständigkeitsbereichs.
- Es verpflichtet für alle Mitarbeiter(innen) zur Einhaltung der IT-Richtlinie.
- Es ist eine Aufforderung an alle, entdeckte Sicherheitsprobleme aufzuzeigen und an eine zu benennende zentrale Stelle weiterzuleiten.

Anlage A zum Anstellungsvertrag von ...

Verpflichtung zur Einhaltung der datenschutzrechtlichen Anforderungen nach der Datenschutz-Grundverordnung (DSGVO)

Frau/Herr ...

wurde darauf verpflichtet, dass es untersagt ist, personenbezogene Daten unbefugt zu verarbeiten.

Nach europäischem Recht und Bundesdatenschutzgesetz (BDSG) sind personenbezogene Daten all jene Informationen, die sich auf eine natürliche Person beziehen oder zumindest beziehbar sind und so Rückschlüsse auf deren Person erlauben.

Personenbezogene Daten dürfen daher nur verarbeitet werden, wenn eine Einwilligung bzw. eine gesetzliche Regelung die Verarbeitung erlauben oder eine Verarbeitung dieser Daten vorgeschrieben ist.

Als Arbeitnehmer der XXX dürfen Sie personenbezogene Daten nur nach einer konkreten Anweisung der XXX verarbeiten.

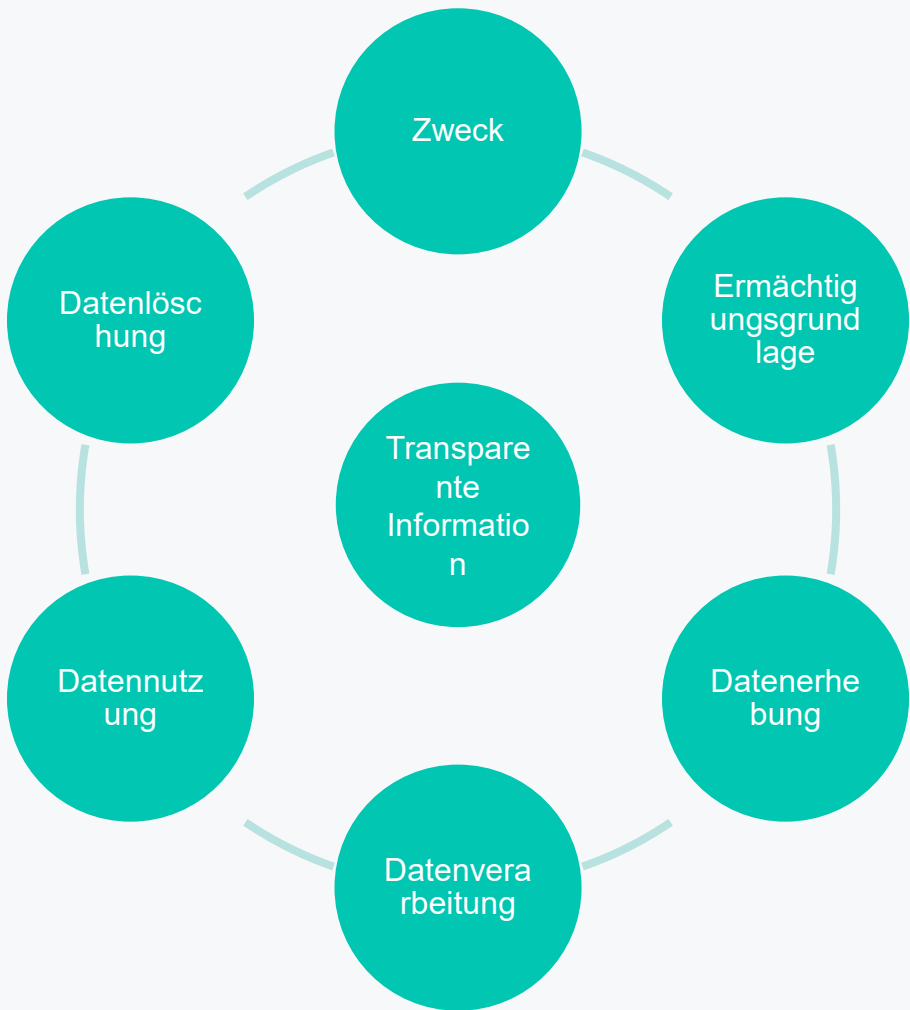
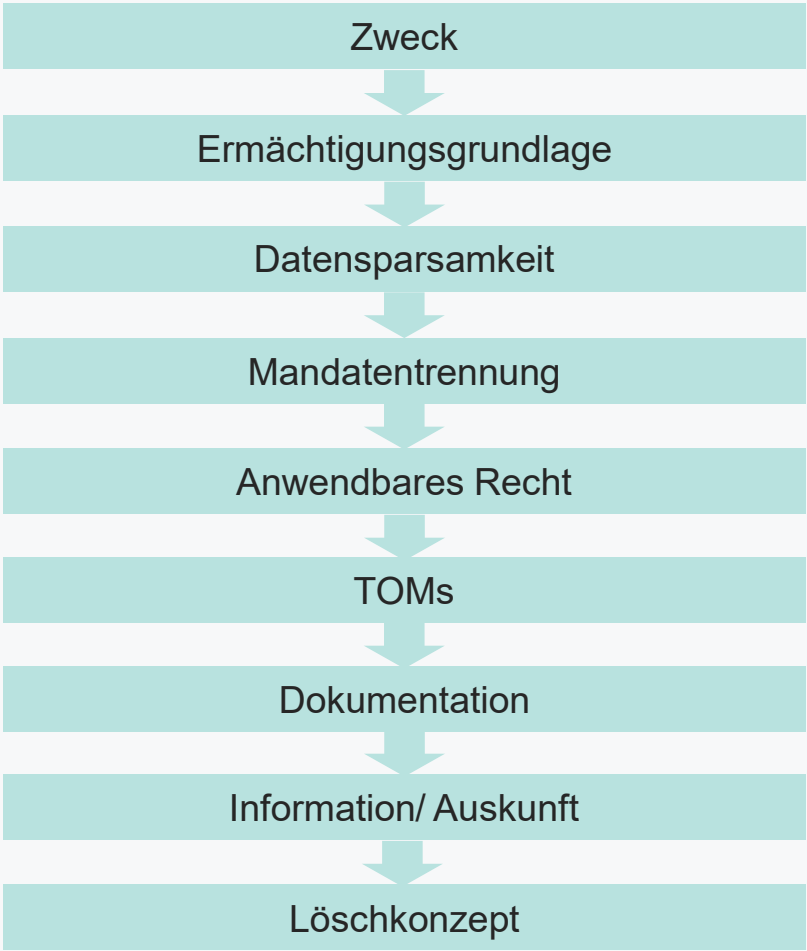
Einzelheiten und konkrete Weisungen zum Umgang mit personenbezogenen Daten bei XXX finden Sie unter Laufwerk Y: Richtlinien

Betroffenenrechte

Transparente Information und Kommunikation – Modalitäten für die Ausübung der Betroffenenrechte Art. 12 DSGVO	DSGVO		BDSG Ergänzend zur DSGVO
	Informationspflichten Art. 13, 14 DSGVO	bei der Erhebung - beim Betroffenen (Art. 13 DSGVO) - nicht beim Betroffenen (Art. 14 DSGVO)	§§ 32, 33 BDSG Ausnahmen
	Auskunft Art. 15 DSGVO		§ 34 BDSG Ausnahmen
	Berichtigung Art. 16 DSGVO		
	Löschung Art. 17 DSGVO		§ 35 BDSG Ausnahmen
	Einschränkung der Verarbeitung, Art. 18 DSGVO		
	Datenportabilität Art. 20 DSGVO		

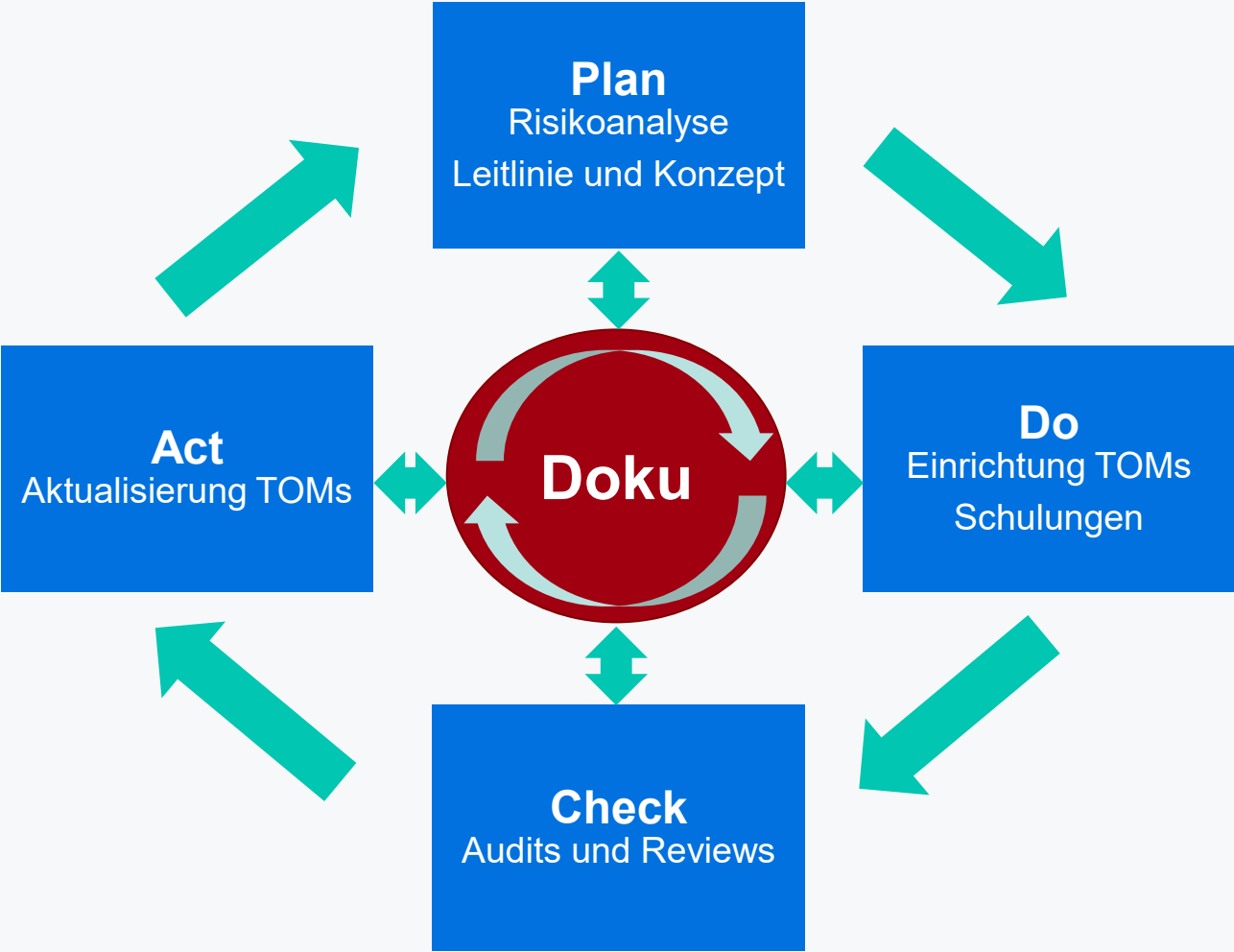
Quelle: Eigene Darstellung

Pflichten der verantwortlichen Stelle



Quelle: Eigene Darstellung

Aufbau- und Ablauforganisation



Quelle: Schrahe & Städter, 2019

Vorbereitung



1. Bewusstsein

- Sicherstellen, dass die Entscheidungsträger und Schlüsselpersonen die Anforderungen der DSGVO kennen.

2. Eigene Daten/Information

- Dokumentieren, welche PbDaten vorhanden sind, woher diese stammen und mit wem diese geteilt werden.
- Klassifizierung der Daten.
- Datensilos vermeiden.

3. Datenschutz-erklärungen

- Entsprechende Ausführungen, z.B. auf den Websites und in Newslettern überprüfen und überarbeiten.

4. Rechte betroffener Personen

- Verfahren die sicherstellen, dass alle Rechte berücksichtigt werden.
- Löschung PbD oder Bereitstellung PbD auf elektronischem Wege und in einem gängigen Format.

5. Informationspflichten

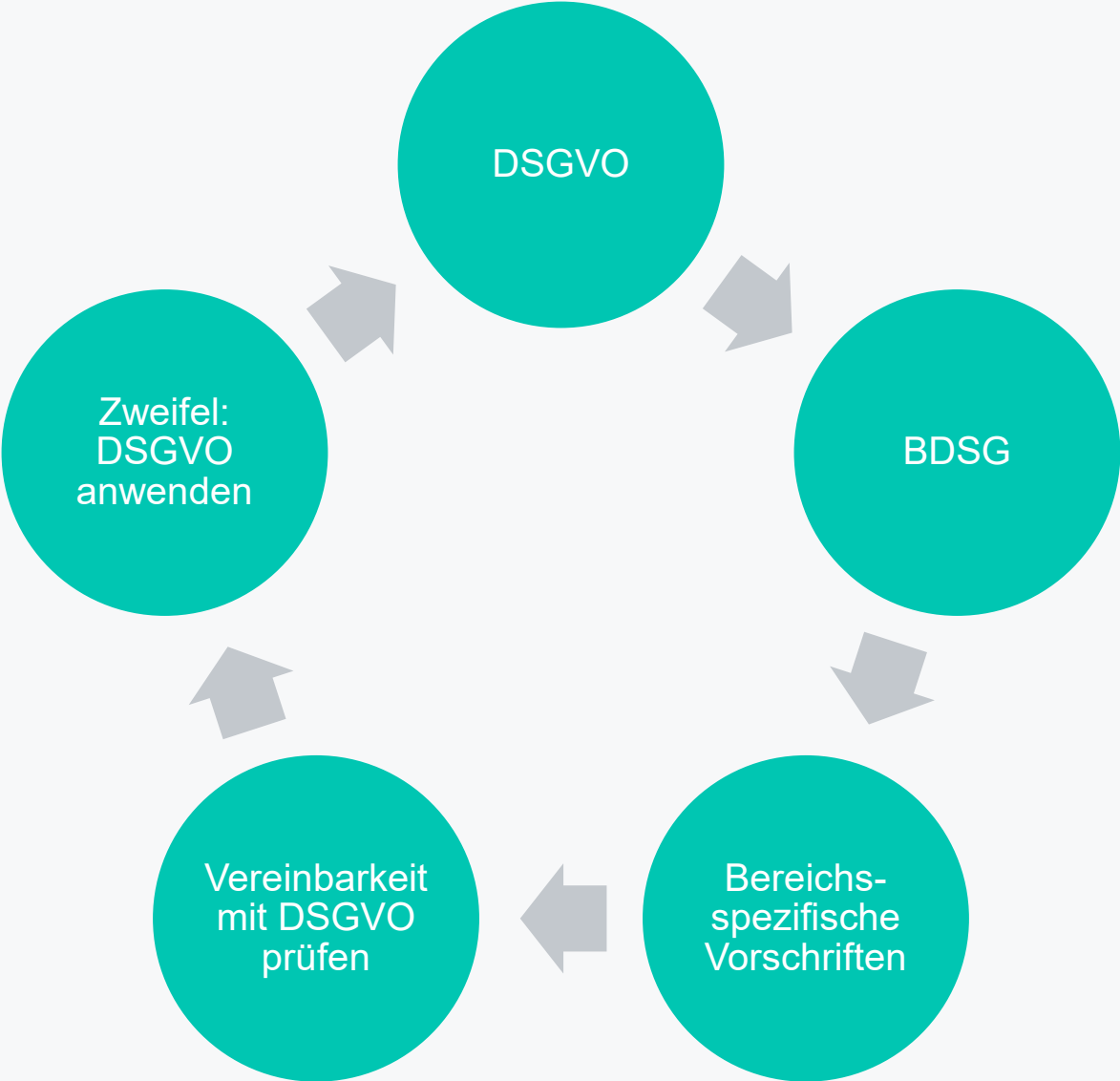
- Aktualisieren der Verfahren
- Neue Verfahren bzgl. Auskunft, Berichtigung, Löschung, Einschränkung der Verarbeitung

Struktur und Verantwortlichkeit im Unternehmen

Bewusstsein im Unternehmen schaffen, dass Datenschutz Chefsache ist

- Datenschutzleitlinie
- Beschreibung der Datenschutzziele
- Regelung der Verantwortlichkeiten
- Bewusstsein über Datenschutzrisiken
- Transparenz über mögliche Zielkonflikte (z.B. zwischen Marketing- und Rechtsabteilung)

Anwendungsvorrang des EU-Rechts



Vorbereitung

1.

Bewusstsein

- Sicherstellen, dass die Entscheidungsträger und Schlüsselpersonen die Anforderungen der DSGVO kennen.

2.

Eigene Daten/Informationen

- Dokumentieren, welche PbDaten vorhanden sind, woher diese stammen und mit wem diese geteilt werden.
- Klassifizierung der Daten.
- Datensilos vermeiden.



3.

Datenschutz- erklärungen

- Entsprechende Ausführungen, z.B. auf den Websites und in Newslettern überprüfen und überarbeiten.

4.

Rechte betroffener Personen

- Verfahren die sicherstellen, dass alle Rechte berücksichtigt werden.
- Löschung PbD oder Bereitstellung PbD auf elektronischem Wege und in einem gängigen Format.

5.

Informations- pflichten

- Aktualisieren der Verfahren
- Neue Verfahren bzgl. Auskunft, Berichtigung, Löschung, Einschränkung der Verarbeitung

Eigene Daten und Informationen

Dokumentation, welche PbD vorhanden sind, woher sie stammen und mit wem sie geteilt werden

- Klassifikation der Daten, z.B. gemäß einer IT-Richtlinie
- Datentrennung um Compliance-Anforderungen zu erfüllen
- Keine Datensilos
- Vorbereitung für die Umsetzung von Löschvorgaben

Übersicht zu Verarbeitungen

- Verzeichnis von Verarbeitungstätigkeiten gem. Art. 30 DSGVO
- Berücksichtigung datenschutzrechtlicher Belange bei Beginn oder Änderung eines jeden Prozesses im Unternehmen (Privacy by Design – Art. 25 DSGVO)

Einbindung Externer

- Abschluss der erforderlichen Vereinbarungen mit allen Auftragsverarbeitern mit dem Mindestinhalt nach Art. 28 Abs. 3 DSGVO

[BayLDA Fragebogen DSGVO]

Verantwortlicher

„...‘Verantwortlicher‘ die natürliche oder juristische Person, Behörde, Einrichtung oder andere Stelle, die allein oder gemeinsam mit anderen über die Zwecke und Mittel der Verarbeitung von personenbezogenen Daten entscheidet; sind die Zwecke und Mittel dieser Verarbeitung durch das Unionsrecht oder das Recht der Mitgliedstaaten vorgegeben, so kann der Verantwortliche beziehungsweise können die bestimmten Kriterien seiner Benennung nach dem Unionsrecht oder dem Recht der Mitgliedstaaten vorgesehen werden;...“

[Art. 4 Nr. 7 DSGVO]

„...‘Verarbeitung‘ jeden mit oder ohne Hilfe automatisierter Verfahren ausgeführten Vorgang oder jede solche Vorgangsreihe im Zusammenhang mit personenbezogenen Daten wie das Erheben, das Erfassen, die Organisation, das Ordnen, die Speicherung, die Anpassung oder Veränderung, das Auslesen, das Abfragen, die Verwendung, die Offenlegung durch Übermittlung, Verbreitung oder eine andere Form der Bereitstellung, den Abgleich oder die Verknüpfung, die Einschränkung, das Löschen oder die Vernichtung;...“

[Art. 4 Nr. 2 DSGVO]

Datenumgang/ Datenzweck



Auftragsverarbeitung

Auftragsverarbeitung gemäß Art. 28 DSGVO

- Weisungsgebundene Auslagerung von Datenverarbeitungstätigkeiten an andere Stellen
- Besonderheiten Outsourcing und Cloud-Computing
- Remote-Support

Übermittlung von Daten

Protokollierung

2-Stufen-Test für Auftragsverarbeitung

1. Angemessenes Datenschutz-Niveau
2. Datenschutzrechtlicher Erlaubnistatbestand

Wird später vertieft.

Funktionsübertragung

Inanspruchnahme fremder Fachleistungen bei eigenständiger Verantwortlichkeit, z.B.:

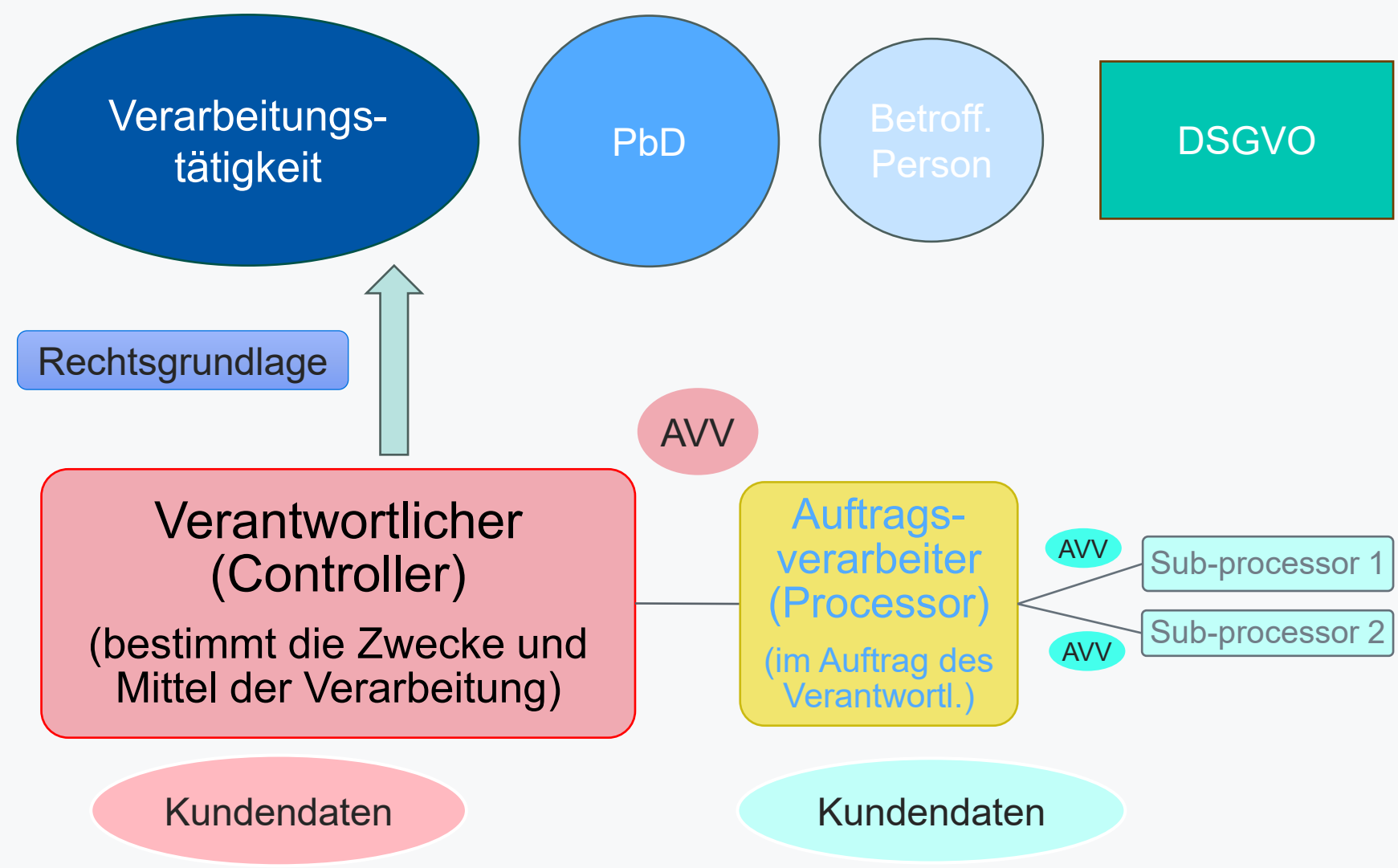
- die Beauftragung von Berufsgeheimnisträgern (Steuerberater, Rechtsanwälte, Wirtschaftsprüfer)
- die Inanspruchnahme von Postdienstleistungen zum Brieftransport
- Beauftragung von Inkassounternehmen

Die Übermittlung der Daten an diese Personen bzw. Institutionen erfolgt auf der Grundlage des Art 6. Abs. 1 f DSGVO zur Wahrung berechtigter Interessen.

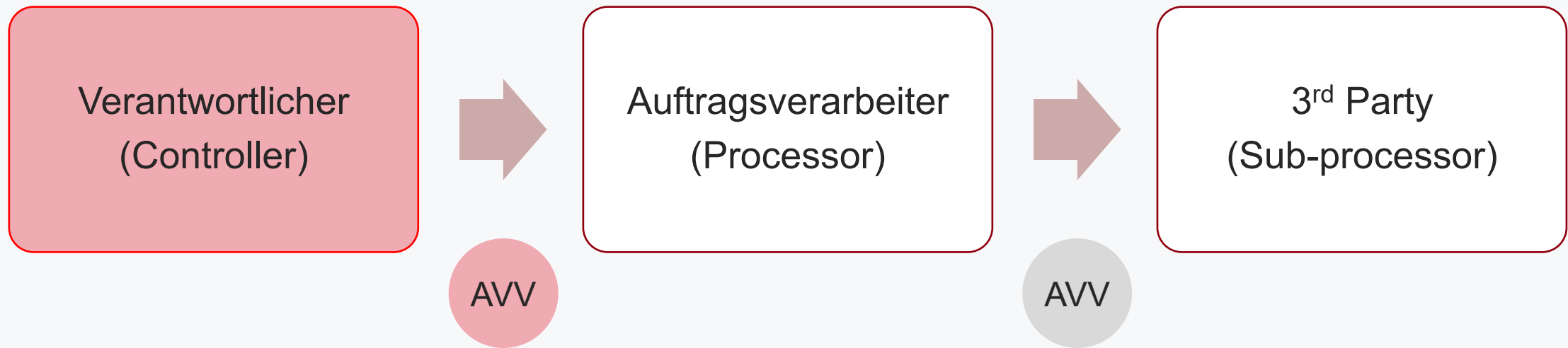
Bei der Beauftragung dieser Personenkreise ist somit kein Vertrag über die Auftragsverarbeitung notwendig.

Außerdem sind auch die Übermittlungen von personenbezogenen Daten an Institutionen aufgrund einer gesetzlichen Verpflichtung bzw. Ermächtigung keine Auftragsverarbeitung (Art. 9 Abs. 2 b und h DSGVO), z.B. die Übermittlung von Daten an die gesetzlichen Unfallversicherungen (§ 201 SGB VII).

Definition und Kontext einer Verarbeitungstätigkeit



Aufgaben des Verantwortlichen



- Aktualisieren des Verzeichnisses der Verarbeitungstätigkeiten
- Schließen eines AVV mit dem Auftragsverarbeiter
- Aktualisieren der Datenschutzerklärung: Information der betroffenen Personen

Vorbereitung

1.

Bewusstsein

- Sicherstellen, dass die Entscheidungsträger und Schlüsselpersonen die Anforderungen der DSGVO kennen.

2.

Eigene Daten/Information

- Dokumentieren, welche PbDaten vorhanden sind, woher diese stammen und mit wem diese geteilt werden.
- Klassifizierung der Daten.
- Datensilos vermeiden.

3.

Datenschutz- erklärungen

- Entsprechende Ausführungen, z.B. auf den Websites und in Newslettern überprüfen und überarbeiten.

4.

Rechte betroffener Personen

- Verfahren die sicherstellen, dass alle Rechte berücksichtigt werden.
- Löschung PbD oder Bereitstellung PbD auf elektronischem Wege und in einem gängigen Format.

5.

Informations- pflichten

- Aktualisieren der Verfahren
- Neue Verfahren bzgl. Auskunft, Berichtigung, Löschung, Einschränkung der Verarbeitung

Datenschutzerklärung und Informationspflichten

Transparenz, Informationspflichten und Sicherstellung der Betroffenenrechte

- Anpassung der Texte zur datenschutzrechtlichen Information der betroffenen Personen bei der Datenerhebung an die Anforderungen nach Art. 13 bzw. 14 DSGVO
 - Rechtsgrundlage(n) für die Verarbeitung personenbezogener Daten; berechnigte Interessen berücksichtigen.
 - Dauer der Speicherung von Daten; Kriterien für die Festlegung dieser Dauer definieren.
 - Berücksichtigung der Rechte betroffener Personen auf Auskunft, Berichtigung, Löschung, Einschränkung der Verarbeitung, auf Widerspruch aufgrund besonderer Situation einer betroffenen Person sowie auf Datenportabilität
 - Anpassung der Werbe-Einwilligungserklärungen für Kunden, Interessenten usw., an die Anforderungen von Art. 7 und 13 DSGVO
- insbesondere: erweiterte Informationspflichten, auch zur jederzeitigen Widerrufbarkeit der Einwilligung
- Verfahren, um Anträge von betroffenen Personen auf Auskunft zu den eigenen Daten nach Art. 15 DSGVO zeitnah und vollständig zu erfüllen (Art. 12 Abs. 1 DSGVO)
 - Verfahren, um Anträge auf Datenübertragbarkeit betroffener Personen zu erfüllen (Art. 20 DSGVO)

TTDSG (1/2)

Infos zum Gesetzgebungsverfahren:

Am 20.05.2021 verabschiedete der Bundestag das Gesetz zur Regelung des Datenschutzes und des Schutzes der Privatsphäre in der Telekommunikation und bei Telemedien (TTDSG).

Formal setzt das TTDSG sehr verspätet europarechtliche Vorgaben aus der E-Privacy-Richtlinie um, die aus dem Jahr 2002 stammt und zuletzt 2009 geändert wurde.

Damit führt man die bereichsspezifischen Datenschutzregeln aus dem Telekommunikationsgesetz (TKG) und dem Telemediengesetz (TMG) in einem Gesetz zusammen und hat sie in diesem Zuge aktualisiert.

Was regelt das TTDSG zu Cookies?

Das TTDSG normiert die bisherige Rechtsprechung von EuGH und BGH und stellt in § 25 Absatz 1 TTDSG (Schutz der Privatsphäre bei Endeinrichtungen) klar, dass Cookies (und vergleichbare Techniken wie Fingerprinting oder die Nachverfolgung über MAC-Adressen, IMEI-Nummern) eine informierte, ausdrückliche und vorherige Zustimmung (Einwilligung) erfordern. Dies gilt entsprechend den Vorgaben der ePrivacy-Richtlinie unabhängig davon, ob dabei personenbezogene Daten anfallen.

TDDDG

Das TTDSG wurde am 13. Mai 2024 in Telekommunikation-Digitale-Dienste-Datenschutz-Gesetz (TDDDG) umbenannt.

TDDDG (2/2)

Die Einwilligung nach Absatz 1 ist nicht erforderlich,

- wenn der alleinige Zweck der Speicherung von Informationen in der Endeinrichtung des Endnutzers oder der alleinige Zweck des Zugriffs auf bereits in der Endeinrichtung des Endnutzers gespeicherte Informationen die Durchführung der Übertragung einer Nachricht über ein öffentliches Telekommunikationsnetz ist oder
- wenn die Speicherung von Informationen in der Endeinrichtung des Endnutzers oder der Zugriff auf bereits in der Endeinrichtung des Endnutzers gespeicherte Informationen unbedingt erforderlich ist, damit der Anbieter eines Telemediendienstes einen vom Nutzer ausdrücklich gewünschten Telemediendienst zur Verfügung stellen kann.
- Der Einsatz nicht notwendiger Dienste, welche Informationen auf Endgeräten speichern oder auslesen auf Grundlage eines berechtigten Interesses nach Art. 6 Abs. 1 Buchst. f DSGVO ist nicht mehr möglich.

Personal Information Management Systeme (PIMS)

- Alternative zum lästigen Cookie-Banner
- Details: https://edps.europa.eu/data-protection/our-work/subjects/systeme-de-gestion-des-informations-personnelles_de
- Verordnungsentwurf der Bundesregierung vom 01.06.2023

Vorbereitung



6. Rechtliche Grundlagen für die Verarbeitung PbD

- Identifizieren der rechtlichen Grundlagen
- Dokumentation



7. Einwilligungen

- Überprüfen, wie Einwilligungen erfasst und verwaltet werden können
- Änderungen umsetzen.

8. Datenschutzvorfälle

- Interne Richtlinien/Verfahren entwickeln und umsetzen, die eine unverzügliche Meldung gewährleisten.

9. Datenschutzfolgenabschätzung

- Bewährte Verfahren zum Risikomanagement umsetzen
- Privacy Impact Assessments (PIA) als Teil davon durchführen.

10. International

- Für die Übermittlung von Daten in Drittländer sind angemessene Schutzmaßnahmen umzusetzen.

Rechtliche Grundlagen und Einwilligungen

Verantwortlichkeit, Umgang mit Risiken

- Angaben zu Verarbeitungstätigkeiten, mit der die Rechtmäßigkeit der Verarbeitung nachgewiesen werden kann, z.B. bezüglich Zwecken, Kategorien personenbezogener Daten, Empfängern und/oder Löschfristen (Art. 5 Abs. 2 DSGVO)
- Prüfen ob die Einwilligungen, auf die eine Verarbeitung gestützt wird, noch den Voraussetzungen der Art. 7 und/oder 8 DSGVO entsprechen
- Datenschutz-Managementsystem, um sicherzustellen und den Nachweis zu erbringen, dass die Verarbeitung gemäß der DSGVO erfolgt (Art 24 Abs. 1 DSGVO)
- Anpassung der Prozesse zur Überprüfung der Sicherheit der Verarbeitung auf die neuen Anforderungen des Art. 32 DSGVO
 - Checklisten zur Auswahl von technischen und organisatorischen Maßnahmen durch eine risikoorientierte Betrachtungsweise auf Basis von Art, des Umfangs, der Umstände und der Zwecke der Verarbeitung sowie der unterschiedlichen Eintrittswahrscheinlichkeit und Schwere der Risiken für die Rechte und Freiheiten
 - Geeignetes Managementsystem zur regelmäßigen Überprüfung, Bewertung und Verbesserung der Sicherheits-Maßnahmen
 - Schutzmaßnahmen wie Pseudonymisierung und der Einsatz von kryptographischen Verfahren zum Schutz vor unbefugten oder unrechtmäßigen Verarbeitungen sowohl bezüglich externer als auch interner „Angreifer“

Vorbereitung

6. Rechtliche Grundlagen für die Verarbeitung PbD

- Identifizieren der rechtlichen Grundlagen
- Dokumentation

7. Einwilligungen

- Überprüfen, wie Einwilligungen erfasst und verwaltet werden können
- Änderungen umsetzen.

8. Datenschutz-vorfälle

- Interne Richtlinien/Verfahren entwickeln und umsetzen, die eine unverzügliche Meldung gewährleisten.



9. Datenschutzfolgenabschätzung

- Bewährte Verfahren zum Risikomanagement umsetzen
- Privacy Impact Assessments (PIA) als Teil davon durchführen.

10. International

- Für die Übermittlung von Daten in Drittländer sind angemessene Schutzmaßnahmen umzusetzen.

Incident Response Management

Die EU-DSGVO sieht die Dokumentation von Datenschutzvorfällen (Art. 33 Abs. 5 DSGVO) vor. Ebenso ist der Aufsichtsbehörde die Verletzung des Schutzes personenbezogener Daten zu melden (Art. 33 Abs. 1 DS- GVO).

Die Meldepflichten bei Datenpannen an eine Aufsichtsbehörde haben auf jeden Vorfall zu erfolgen, wenn ein „Risiko“ für die Rechte und Pflichten der Betroffenen entsteht, und zwar **innen 72 Stunden**.

Zusätzlich muss auch der Betroffene unverzüglich über eine Datenpanne informiert werden, wenn diese voraussichtlich zu einem "hohen Risiko" führt.

Datenschutzvorfälle

Datenschutzverletzungen

- Meldung von Verletzungen des Schutzes personenbezogener Daten innerhalb von 72 Stunden an die Aufsichtsbehörde gem. Art. 33 DSGVO
- Geeignete Methode zur Ermittlung des Risikos
- Prozess definieren und umsetzen, wie mit potenziellen Verletzungen intern umzugehen ist
- Prozess definieren und umsetzen wer, wann und wie mit der Datenschutzaufsichtsbehörde kommuniziert wird.

Vorbereitung

6. Rechtliche Grundlagen für die Verarbeitung PbD

- Identifizieren der rechtlichen Grundlagen
- Dokumentation

7. Einwilligungen

- Überprüfen, wie Einwilligungen erfasst und verwaltet werden können
- Änderungen umsetzen.

8. Datenschutzvorfälle

- Interne Richtlinien/Verfahren entwickeln und umsetzen, die eine unverzügliche Meldung gewährleisten.

9. Datenschutzfolgenabschätzung

- Bewährte Verfahren zum Risikomanagement umsetzen
- Privacy Impact Assessments (PIA) als Teil davon durchführen.

10. International

- Für die Übermittlung von Daten in Drittländer sind angemessene Schutzmaßnahmen umzusetzen.



Datenschutzfolgenabschätzung

- Geeignete Methode zur Bestimmung der Frage, ob eine Datenschutz-Folgenabschätzung durchzuführen ist
- Geeignete Risikomethode zur Durchführung einer Datenschutz-Folgenabschätzung
- Datenschutz-Managementsystem, um sicherzustellen und den Nachweis zu erbringen, dass die Verarbeitung gemäß der DSGVO erfolgt (Art 35 DSGVO)
- Anpassung der Prozesse zur Überprüfung der Sicherheit der Verarbeitung auf die neuen Anforderungen des Art. 32 DSGVO
- Checklisten zur Auswahl von technischen und organisatorischen Maßnahmen durch eine risikoorientierte Betrachtungsweise auf Basis von Art, des Umfangs, der Umstände und der Zwecke der Verarbeitung sowie der unterschiedlichen Eintrittswahrscheinlichkeit und Schwere der Risiken für die Rechte und Freiheiten
- Geeignetes Managementsystem zur regelmäßigen Überprüfung, Bewertung und Verbesserung der Sicherheits-Maßnahmen

Vorbereitung

6. Rechtliche Grundlagen für die Verarbeitung PbD

- Identifizieren der rechtlichen Grundlagen
- Dokumentation

7. Einwilligungen

- Überprüfen, wie Einwilligungen erfasst und verwaltet werden können
- Änderungen umsetzen.

8. Datenschutz-vorfälle

- Interne Richtlinien/Verfahren entwickeln und umsetzen, die eine unverzügliche Meldung gewährleisten.

9. Datenschutz-Folgenabschätzung

- Bewährte Verfahren zum Risikomanagement umsetzen
- Privacy Impact Assessments (PIA) als Teil davon durchführen.

10. International

- Für die Übermittlung von Daten in Drittländer sind angemessene Schutzmaßnahmen umzusetzen.



Was ist eine „Übermittlung an ein Drittland“?

„geographische Interpretation“

wird sich wohl gegenüber der „Anwendungsbereich-basierten Interpretation“ durchsetzen

Daten, die:

- gemäß Art. 3 unter die DSGVO fallen
- und sich räumlich in der EU befinden,
- das EU-Territorium verlassen bzw. wenn aus einem Nicht-EU- bzw. Nicht-EWR- Land Zugriff auf diese Daten genommen wird

Kernkriterium für eine Übermittlung in ein Drittland:

Daten, die sich auf EU-Territorium befinden, landen außerhalb des EU-Territoriums.

Anwendungsfälle

- Wenn Daten von einer EU-Niederlassung X des Verantwortlichen an eine davon zu unterscheidende Nicht-EU-Niederlassung Y (wenn auch desselben Verantwortlichen) übermittelt werden, dann wird mehrheitlich eine „Übermittlung in ein Drittland“ bejaht.
- Auch ein Auftragsverarbeiter gilt als „Datenexporteur“, wenn er es ist, der die Daten aus dem EU-/EWR-Territorium hinausbefördert.

Erlaubnistatbestände für Datenübermittlung

Angemessenheitsbeschluss (Art. 45 DSGVO)

- ausschließliche Zuständigkeit der Kommission
- Katalog der Elemente, die bei der Bewertung des Datenschutzniveaus in Drittländern zu berücksichtigen sind
- [Privacy Shield 2.0: Angemessenheitsbeschluss nach Art. 45 DSGVO für das EU-US Data Privacy Framework vom 11.07.2023](#)

Geeignete Garantien ohne Genehmigung der Aufsichtsbehörde (Art. 46 DSGVO)

- Binding Corporate Rules (Art. 47 DSGVO)
- Standardvertragsklauseln nach Art. 93 Abs. 2 DSGVO
- Genehmigte Verhaltensregeln nach Art. 40 DSGVO (Codes of Conduct)
- Zertifizierungen nach Art. 42 DSGVO

Geeignete Garantien mit Genehmigung der Aufsichtsbehörde

- Vertragsklauseln
- Verwaltungsvereinbarungen

Verstöße

Es gibt viele Verstöße gegen den Schutz von personenbezogenen und betrieblichen Daten. Die meisten geschehen aus Unkenntnis, die wenigsten aus Vorsatz.

Verstöße führen immer zu einer Gefährdung personenbezogener, aber auch betrieblicher Daten. Beispiele:

- Datenmissbrauch bei unzulässiger Nutzung (z.B. zu Werbezwecken)
- Datenverfälschung auf schlecht abgesicherten Computern
- Datenverluste z.B. bei mobilen Computern (oder Handys)
- Datenzerstörung aus Unachtsamkeit (z.B. eingeschleppte Viren und Trojaner)

Wer gegen den Datenschutz verstößt, muss auch mit arbeitsrechtlichen Konsequenzen rechnen!

Fallbeispiele

Gruppenarbeit

Bitte beantworten Sie die folgenden Fragen. Gehen Sie dabei wie folgt vor:

- Teambildung erfolgt durch die Teilnehmer (2-3 Personen pro Team).
- Schildern sie die jeweils mögliche Vorgehensweise
- Welche Schwachstellen bzw. Risiken sehen sie?
- Wie können Sie dies auf Basis aktueller Kenntnisse und Erfahrungen datenschutzkonform umsetzen?

Fallbeispiele:

1. Bauherr benötigt die Tel. Nr. eines Lieferanten und erkundigt sich hierzu telefonisch bei Ihrem Sekretariat. Außerdem benötigt er noch die Mobil-Nr. Ihres Projektleiters. Wie gehen Sie damit um?
2. Wie gehen sie mit Besuchern am Empfang um? Gibt es bestimmte Vorgehensweisen für Handwerker oder für das Reinigungspersonal?
3. Ein Bewerber kommt vorbei und legt seine Unterlagen auf den Tisch im Sekretariat. Wie verhalten Sie sich?
4. Ein potentieller Geschäftspartner überreicht Ihnen seine Visitenkarte. Dürfen Sie die Daten speichern bzw. verarbeiten?
5. Sie wollen ein externes Konstruktionsbüro in Ihre Geschäftsprozesse einbinden. Was müssen Sie dabei berücksichtigen? Welche Gemeinsamkeiten bzw. Unterschiede gibt es für einen IT-Dienstleister bzw. einen Steuerberater?
6. Sie erhalten ein Schreiben für eine „Datenschutzrechtliche Selbstauskunft“ (gem. Art. 15 DSGVO). Wie verhalten Sie sich?
7. Im Anschluss an die Selbstauskunft (siehe Punkt 6.) verlangt der Antragsteller die Löschung seiner Daten. Kommen Sie bzw. wie kommen Sie diesem Löschbegehren nach?
8. Ihr Geschäftspartner schlägt Ihnen vor, zur weiteren Abstimmung WhatsApp zu nutzen. Außerdem soll für den Austausch der Projektdokumentation Dropbox genutzt werden. Was halten Sie denn davon?
9. Ihr Notebook oder Handy wird gestohlen. Wie verhalten Sie sich bzw. welche Schritte leiten Sie in welcher Reihenfolge ein?
10. Phishing-Mails sind allgegenwärtig. Klassifizieren sie diese anhand folgender Beispiele. Wie können Sie sich schützen?
11. Sie finden einen USB-Stick. Wie verhalten Sie sich? Bitte begründen Sie.

Fallbeispiel 12

Sehr geehrter Herr Städter,

ich habe eine datenschutzrelevante Frage.

Für eine Baustelle ist eine Zutrittskontrolle vorgesehen. Hierfür sollen Ausweise erstellt werden. Die dafür benötigten persönlichen Daten soll der externe Bauleiter im Auftrag des Bauherrn mittels angehängten Formulars einsammeln und an den Sicherheitsdienst übermitteln.

Wie soll ich mich verhalten.

- 1) Ich habe die persönlichen Daten meiner Teamkollegen nicht zur Verfügung und vermutlich auch nicht das Recht die bei uns intern einzusammeln oder gar weiterzuleiten.
- 2) Ich habe persönlich kein Interesse, dass der Bauleiter oder Bauherr weiß, wann ich geboren bin oder wo ich wohne.
- 3) Muss da nicht zumindest eine Erklärung her, was mit unseren Daten gemacht wird (Speicherung/ Löschen ...)

Für eine zeitnahe Antwort bedanke ich mich und stehe auch gern für ein Gespräch/ Rückfragen zur Verfügung.

Mit freundlichen Grüßen

i. A. Dipl.-Ing. NN

Mögliche Lösung für Fallbeispiel 12

Sehr geehrter Herr NN,

der Bauherr beruft sich wahrscheinlich auf „berechtigte Interessen des Verantwortlichen“ (Art. 6 f DSGVO) als Rechtsgrundlage für die Bearbeitung personenbezogener Daten. Wie dem auch sei: Gemäß Art. 15 DSGVO haben sie ein Auskunftsrecht; sie können den Bauherren bitten, ihnen folgende Informationen mitzuteilen:

- Welche Daten über ihre Person konkret bei dem Bauherrn gespeichert oder verarbeitet werden
- Verarbeitungszwecke ihrer Daten
- Empfänger oder Kategorien von Empfängern, die ihre Daten erhalten werden;
- die geplante Dauer für die Speicherung ihrer Daten, oder, falls dies nicht möglich ist, die Kriterien für die Festlegung dieser Dauer;
- über das Bestehen ihrer Rechte auf Berichtigung, Löschung oder Einschränkung der Verarbeitung ihrer Daten, ebenso wie über ihr Widerspruchsrecht gegen diese Verarbeitung nach Art. 21 DSGVO und ihr Beschwerderecht bei der zuständigen Aufsichtsbehörde.

Außerdem ist der Bauherr seiner Informationspflicht bei der Erhebung von personenbezogenen Daten - zum Zeitpunkt der Erhebung dieser Daten - gemäß Art. 13 DSGVO nachzukommen. Die Informationspflichten betreffen sämtliche Verarbeitungen personenbezogener Daten, d.h. sowohl Verarbeitungen im Online- als auch im „Offline-Bereich“, also auch in Papierakten. Hinsichtlich der Art und Weise der Ausgestaltung sowie der Bereitstellung der Datenschutzinformationen sind die Vorgaben in Art. 12 DSGVO zu beachten („in präziser, transparenter, verständlicher und leicht zugänglicher Form in einer klaren und einfachen Sprache zu übermitteln“).

Auch ist mir nicht klar, warum der Bauherr Daten (z.B. Geburtsdatum und Privatadresse eines Mitarbeiters des Unternehmens) benötigt. Gemäß Art. 5c DSGVO müssen personenbezogene Daten bei ihrer Verarbeitung "dem Zweck angemessen und erheblich sowie auf das für die Zwecke der Verarbeitung notwendige Maß beschränkt sein („Datenminimierung“)“. Hier sollte eine Begründung geliefert werden, warum diese Kategorien personenbezogener Daten verarbeitet werden.

Kontaktdaten von Kunden (F)

Wenn ich Kundenkontaktdaten zwischen meinem Mobiltelefon und meinem PC per Cloud (Google/Apple) synchronisiere, benötige ich sowohl die Einwilligung der Kunden als auch einen Vertrag zur Auftragsverarbeitung mit Google/Apple?

Kontaktdaten von Kunden (A)

Richtig; dies gilt auch für WhatsApp. Unzulässig ist, wenn die App bei der Installation automatisch die gesamten Kontaktdaten des mobilen Endgerätes auf den US-Server des Betreibers hochlädt.

Die Kontaktdaten von Kunden, Lieferanten, Herstellern und Kooperationspartnern stellen teilweise personenbezogene Daten dar und dürfen nicht an den Cloud-Anbieter ohne Rechtsgrundlage transferiert werden.

Datenübertragung, Datenschutzerklärung (F)

Muss man schon bei einem Kontaktformular die Daten verschlüsselt übertragen? Gibt es ein Muster, was auf die Homepage muss?

Datenübertragung, Datenschutzerklärung (A)

Personenbezogene Daten müssen verschlüsselt übertragen werden (TLS oder Transport Layer Security). Adäquate technische-organisatorische Maßnahmen (Art. 32 DSGVO) sind umzusetzen.

Die DSGVO erweitert den Umfang und die Art der Pflichtangaben auf der Website erheblich; eine verständliche und transparente Sprache wird gefordert.

Es muss eine Datenschutzerklärung angeboten werden. Auch sollte bereits per Pop-Up auf die Nutzung von Cookies hingewiesen werden und die Einwilligung des Benutzers eingeholt werden.

E-Mail (F)

Was muss ich beachten, wenn ich Personen in Mails in CC oder gar BCC einsetze?

e-Mail (A)

Eine Emailadresse ist ein personenbezogenes Datum, das nur mit Einwilligung des Betroffenen übermittelt werden darf. Unter “cc” kann jedoch jeder Empfänger sehen, an wen sonst noch die e-Mail verschickt wurde. Eine Einwilligung, dass alle anderen Empfänger die eigene e-Mail-Adresse auch sehen, ist i.d.R. nicht gegeben. Bei Nutzung von “bcc” geht die e-Mail auch an alle, aber die e-Mail-Adressen der Empfänger sind nicht sichtbar.

Visitenkarten (F)

Wenn ich eine Visitenkarte überreicht bekomme. Kann, darf ich die Daten dann speichern?

Visitenkarten (A)

„Bei strenger juristischer Auslegung kann man zu dem Schluss kommen, dass ein Unternehmen bei der Übergabe einer Visitenkarte direkt informieren muss, was es mit den Kontaktdaten machen wird“ ... „Für die Kontaktaufnahme zur Abwicklung eines Geschäfts braucht man auch in Zukunft keine Einwilligung“ [S. Dehmel, Bitkom].

Über die Umstände der Datenerhebung muss aber trotzdem informiert werden. „Die Entgegennahme der Visitenkarte für sich genommen löst noch keine Informationspflicht aus“, sagte ein Sprecher der Berliner Beauftragten für Datenschutz und Informationsfreiheit. Erst wenn die darauf enthaltenen Daten gespeichert würden, sehe die Verordnung vor, dass der Betroffene informiert werden müsse.

Empfehlung: Dem Visitenkarteninhaber eine E-Mail zu schicken, in der er Pflichtangaben über die Verarbeitung seiner Daten bekommt und in der er darüber aufgeklärt wird, wie er gegebenenfalls der Verarbeitung widersprechen kann.

Unternehmen und Privatpersonen (F)

Gibt es einen Unterschied in der Zusammenarbeit mit Unternehmen und privaten Bauherren?

Unternehmen und Privatpersonen (A)

Die Vorgehensweise unterscheidet sich nicht zwischen Privatpersonen und Unternehmen/Kommunen.

Laut Artikel 2 DSGVO findet die DSGVO keine Anwendung auf die Verarbeitung personenbezogener Daten, wenn die Verarbeitung „durch natürliche Personen zur Ausübung ausschließlich persönlicher oder familiärer Tätigkeiten“ erfolgt.

... aus dem Umfeld der Studierenden

Vielen Dank für Ihre Aufmerksamkeit!